

Préparation Entretien RH/Technique - Synacktiv (Partie Windows & Linux)

Concepts Windows et Linux expliqués en détail

1. Pass The Hash (PtH)

Principe :

- Utilise directement le **hash du mot de passe** (NTLM) pour s'authentifier sans connaître le mot de passe en clair.

Analogie :

- Comme présenter une **copie d'un QR code** de carte d'identité au lieu de la vraie.

Détail technique :

- Hash NTLM récupéré via LSASS/Mimikatz
- Utilisable via `psexec.py`, `wmiexec.py`, Metasploit
- Fonctionne car NTLM accepte le hash directement pour l'authentification

Défense :

- Désactiver NTLM si possible, privilèges minimaux, LAPS
-

2. Kerberoasting

Principe :

- Récupération de **tickets Kerberos chiffrés avec le mot de passe d'un compte de service** (SPN), pour casser le mot de passe offline.

Exploitation :

1. L'utilisateur demande un TGS pour un service
2. Le TGS est chiffré avec le hash du compte de service
3. L'attaquant tente un bruteforce offline du hash

Défense :

- Mots de passe forts pour les comptes de service
 - Compte de service gérés automatiquement (MSA/gMSA)
-

3. Mimikatz

Qu'est-ce que c'est ?

- Outil open-source d'extraction d'identifiants Windows (mots de passe, hash, tickets Kerberos)

Fonctions principales :

- `sekurlsa::logonpasswords` : mots de passe en mémoire
- `lsadump::sam` : dump des hash locaux
- `kerberos::golden, ::ptt` : tickets

Prérequis :

- Droits admin / SYSTEM

Défense :

- Credential Guard, LSASS protection, privilèges minimales
-

4. sudo (Linux)

Définition :

- Permet à un utilisateur d'exécuter une commande avec les droits d'un autre utilisateur (souvent root)

Fichier `/etc/sudoers` :

- Contrôle qui peut faire quoi (commande `sudo -l`)

Risques :

- Commandes mal configurées → escalade de privilèges
-

5. Docker

Concept :

- Conteneur léger, partageant le noyau de l'OS hôte mais isolé au niveau fichier/réseau

Risques :

- Accès à `/var/run/docker.sock` = accès root
- Mode privilégié dangereux

Attaque typique :

```
docker run -v /:/mnt -it alpine chroot /mnt sh
```

Concepts supplémentaires

Kerberos**Architecture :**

- Client, KDC (AS + TGS), Service

Processus :

1. AS-REQ/AS-REP : obtention du TGT
 2. TGS-REQ/TGS-REP : obtention du TGS (service ticket)
 3. Authentification au service via le TGS
-

Golden Ticket

- Forger un **TGT** avec le hash du compte **krbtgt**
- Accès total au domaine (même Domain Admin)
- Défense : rotation du mot de passe **krbtgt**

Silver Ticket

- Forger un **ticket de service** avec le hash du **compte de service**
 - Plus discret, ne passe pas par le KDC
-

LSASS

- Processus Windows contenant identifiants, hash, tickets
 - Cible de Mimikatz
 - Défense : RunAsPPL, Credential Guard, segmentation
-

Active Directory (AD)

- Annuaire LDAP de Windows
 - Contient utilisateurs, machines, groupes, GPO, OU
 - Base des attaques Kerberos
-

BloodHound

- Outil de post-exploitation
 - Cartographie des relations et privilèges AD
 - Utilise SharpHound pour collecter les données
-

UAC Bypass

- Contournement de l'élévation UAC par des binaires autoElevate
 - Ex : **fodhelper.exe**, **eventvwr.exe**
 - Prévention : UAC strict, surveillance
-

Service Abuse (Windows)

- Si un service SYSTEM est modifiable par un user, il peut être détourné
 - Changement du **BinPath** pour injecter une backdoor
-

Linux - Concepts sécurité

SetUID / SetGID

- Exécutable avec bit SetUID = s'exécute avec l'identité du propriétaire
- Risque si le binaire est vulnérable

Cron jobs

- Escalade possible si un cron root appelle un script modifiable
- Attention aux chemins relatifs et **PATH**

Linux Capabilities

- Droits root divisés en capabilities
 - Ex : **CAP_NET_BIND_SERVICE**, **CAP_SYS_ADMIN**
 - Commande : `getcap -r / 2>/dev/null`
-

Propositions pour s'entraîner :

- Fiches PDF/Markdown
- QCM ou oral type entretien
- TPs guidés (Kerberoasting, BloodHound, Pass-the-Hash...)